



[Security2] - Security Policy

Task



Scenario

"Our university is launching a new, all-in-one online portal. This portal will handle everything from student registration and grade management to faculty collaboration and research data storage. The system must protect student privacy, ensure academic integrity, and manage potential conflicts of interest among researchers."

Tasks

1. Define the security policy for this portal.
2. Identify the subjects and the objects.
3. Choose a primary access control model or security framework, and justify the choice.
4. Make an access control matrix.

Work through the steps in the order the chapter gives them: analyse a security model (Bell-LaPadula, Biba, Chinese Wall) for your system, use it to choose an access control model (MAC, DAC, RBAC), then translate that into an access control matrix. This is an individual assignment. See the last slides of *Ch4 - Authorization*.

1. Task 1: Define the security policy for this portal.

- **Answer:** ตอบตามหลัก CIA แล้วทำการแบ่งตาม Definition ของ Security Policy คือแบ่งเป็น Secure และ Insecure
 - **Confidentiality:**
 - *Authorized state:* ข้อมูลการนักศึกษา มีแค่นักศึกษาและอาจารย์เจ้าของวิชาและผู้ดูแลระบบที่ read ได้ & งานวิจัยที่ยังไม่ publish มีแค่นักวิจัยที่เกี่ยวข้องเท่านั้นที่ read ได้
 - *Unauthorized state:* บุคคลภายนอก หรือนักศึกษาคนอื่น ดูที่ไม่ใช่ของตนเองไม่ได้ & ผู้ที่ไม่เกี่ยวข้องกับงานวิจัยนี้ไม่สามารถ read ได้
 - **Integrity:**
 - *Authorized state:* อาจารย์เจ้าของวิชาหรือผู้ดูแลระบบ alter เกรดได้ & งานวิจัยที่ยังไม่ publish มีแค่นักวิจัยที่เกี่ยวข้องเท่านั้นที่ alter ได้
 - *Unauthorized state:* นักศึกษา write เกรดตัวเองไม่ได้ & ผู้ที่ไม่เกี่ยวข้องกับงานวิจัยนี้ไม่สามารถ alter ได้
 - **Availability:**
 - *Authorized state:* ผู้ใช้งานสามารถเข้าถึงระบบportal เพื่อลงทะเบียน ดูเกรด หรือทำงานร่วมกันได้เมื่อต้องการ ตามที่อนุญาต
 - *Unauthorized state:* ระบบหยุดการทำงานจากการโจมตีหรือเกิดข้อขัดข้องที่ทำให้ผู้ใช้งานที่มีสิทธิ์ไม่สามารถเข้าถึงระบบเพื่อลงทะเบียนหรือส่งเกรดตามเวลาที่กำหนดได้

2. Task 2: Identify the subjects and the objects.

- **Answer:**

- **Subject:** นักศึกษา, อาจารย์, นักวิจัย, ผู้ดูแลระบบ (Admin)
- **Object:** Registration System, Grade Management System, Student Privacy Data, Research Data, Collaboration Workspace of faculty(ของอาจารย์)

3. Task 3: Choose a primary access control model or security framework, and justify the choice.

- **Answer:**

- **Access control model** ที่เลือกคือ **RBAC: Role-Based Access Control** เนื่องจาก
 - เราอยากกำหนดสิทธิ์แค่ที่จำเป็นตาม role เท่านั้น(มี role ตาม Task2)
 - สามารถใช้ Security Model ได้ (*Bell-Lapadula, Biba, China Wall Model*)
 - ไม่เลือก MAC: Mandatory Access Control เพราะกรณี อาจารย์จะต้องไม่สามารถแก้ไขเกรดวิชาอื่นในได้ แปลว่าไม่privillage เท่ากันหมดในระดับเดียวกัน
 - ไม่เลือก DAC: Discretionary Access Control เพราะ นักศึกษาไม่ควรแก้ไขเกรดตัวเองได้
- **Security Model:**
 - *Bell-Lapadula*: เช่น No read up: ห้ามผู้ใช้ทั่วไปอ่านข้อมูลนักศึกษา & No write down: อาจารย์/Faculty send/copy/write ลงใน work spaceของนักศึกษา
 - *Biba*: เช่น No write up: นักศึกษาห้ามแก้ไขเกรด ที่เป็นของอาจารย์ & No read down: กันreadสิ่งที่เป็นอันตรายต่อ system
 - *China Wall Model*: ใช้จัดการ conflicts of interest ในส่วนของ research data storage

4. Task 4: Make an access control matrix.

	Registration System	Grade Management System	Student Privacy Data	Research Data	Collaboration Workspace of faculty(ของอาจารย์)
นักศึกษา	read, write	read	read, write (own)	deny (ถ้าจะอ่าน ค่อยควroleเป็นนักวิจัย)	deny
อาจารย์	read	read, write (own subject)	read (own subject)	deny (ถ้าจะอ่าน ค่อยควroleเป็นนักวิจัย)	read, write
นักวิจัย	deny	deny	- (อาจจะ เป็นroleซ้อนทับกับroleอื่นจึงไม่จำเป็นต้องมี)	own read, own write (ภายใต้ China wall Model)	deny
ผู้ดูแลระบบ (Admin)	read, execute	read, execute	read, execute	read	read, write, execute